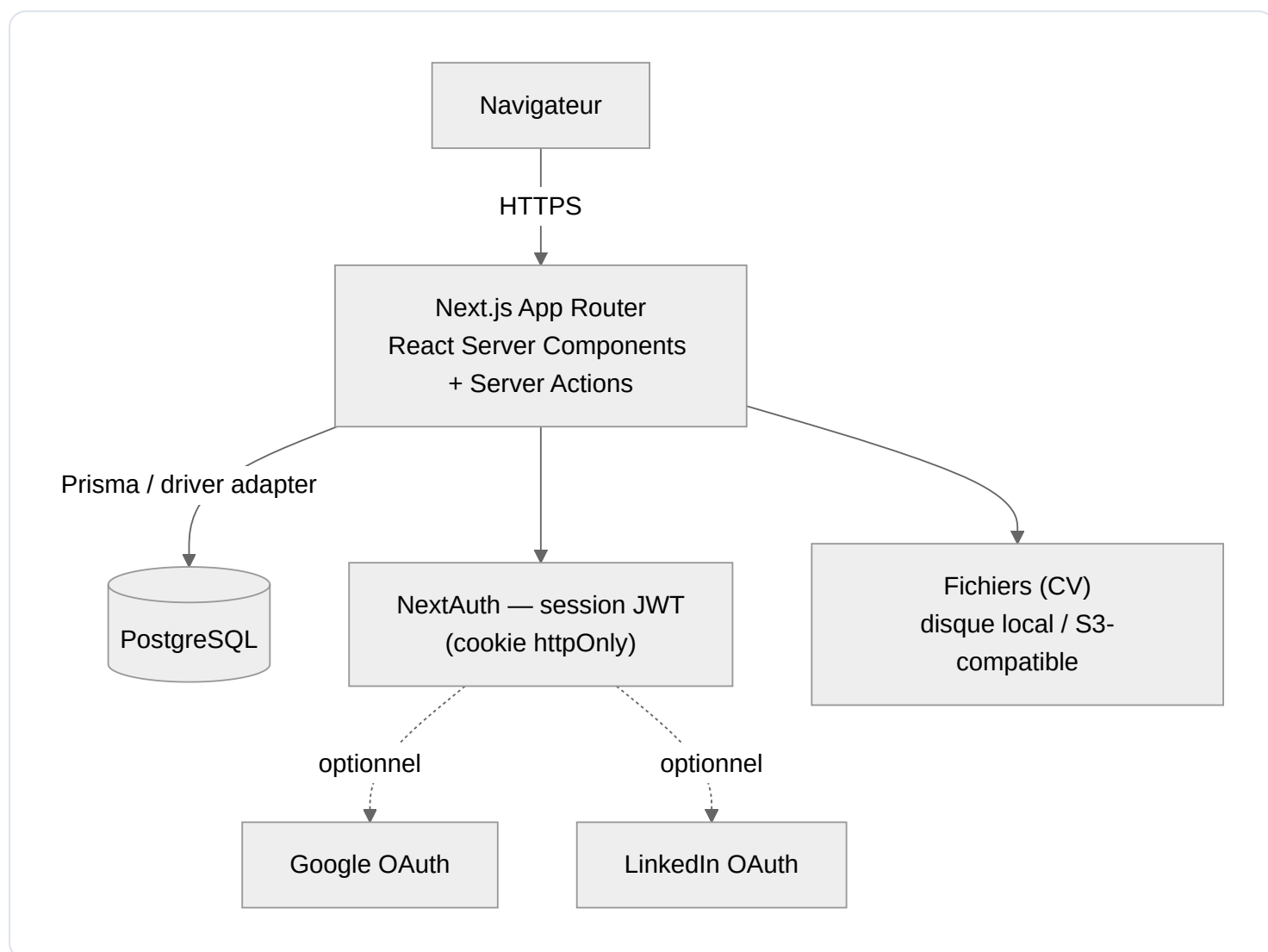


Talents Connect

Une application Next.js unique porte le rendu, la logique métier et l'accès aux données — pas de service séparé, pas d'API REST intermédiaire.

01 Vue d'ensemble système

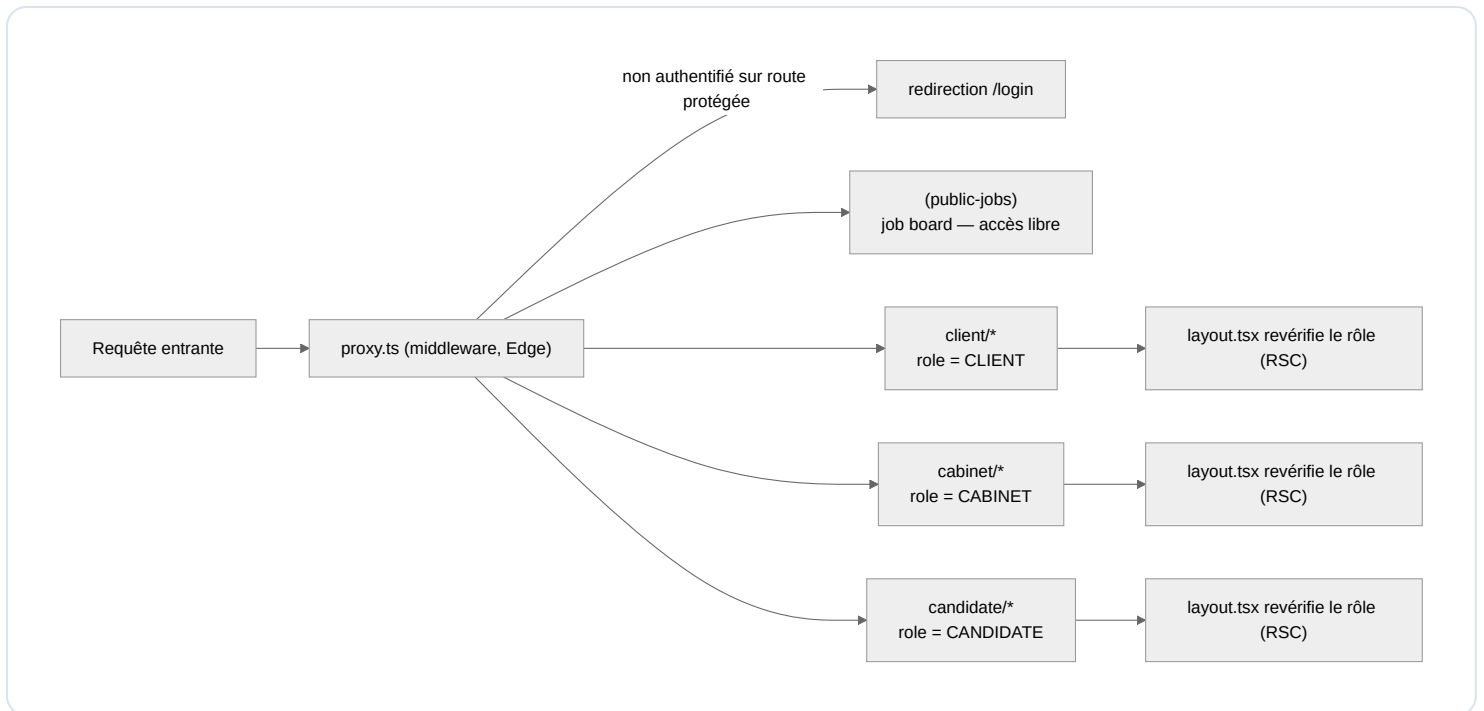
Le navigateur parle uniquement à l'application Next.js, qui centralise l'accès à la base de données et à l'authentification.



Aucune couche API séparée : les composants client appellent directement des *server actions* Next.js, qui s'exécutent côté serveur avec un accès direct à Prisma.

02 Découpage par façade

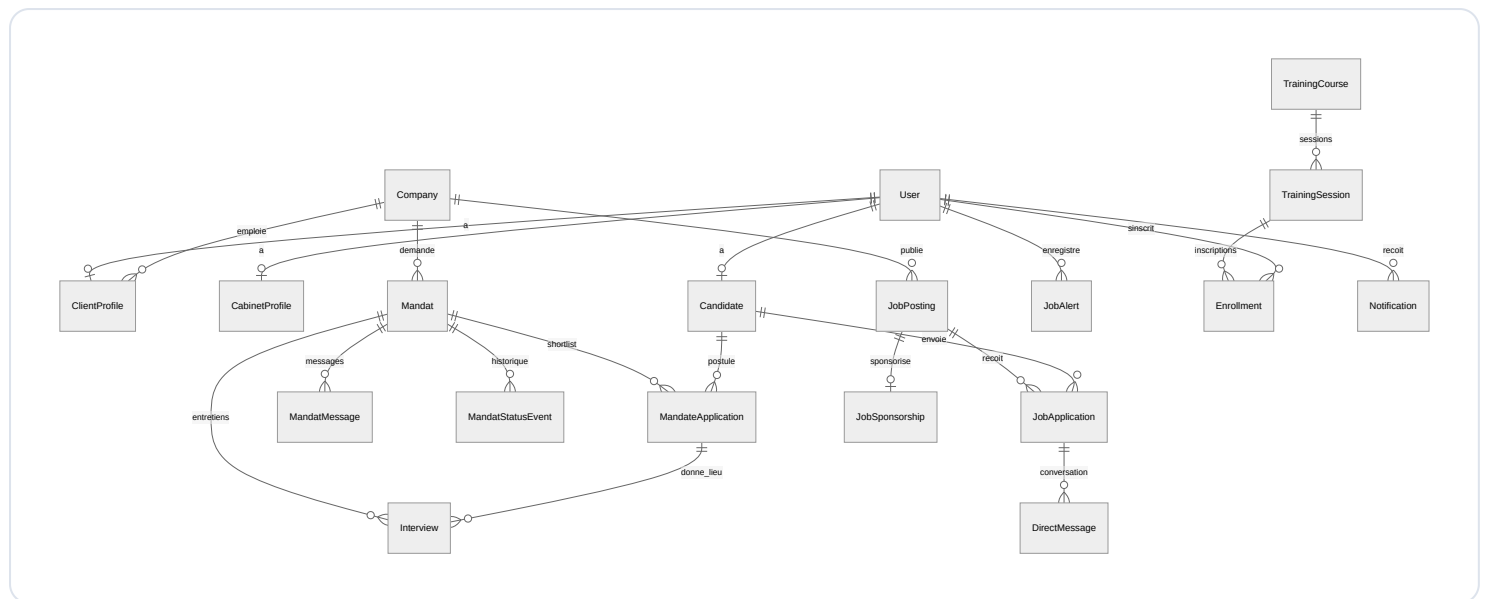
Le rôle de l'utilisateur détermine son espace ; le middleware protège l'accès avant même le rendu de la page.



Double vérification volontaire : le middleware Edge est rapide mais limité (pas d'accès base de données) ; chaque layout de façade vérifie le rôle exact côté serveur avec un accès complet à la session.

03 Modèle de données

24 modèles Prisma. Vue simplifiée des relations principales, regroupées par domaine fonctionnel.



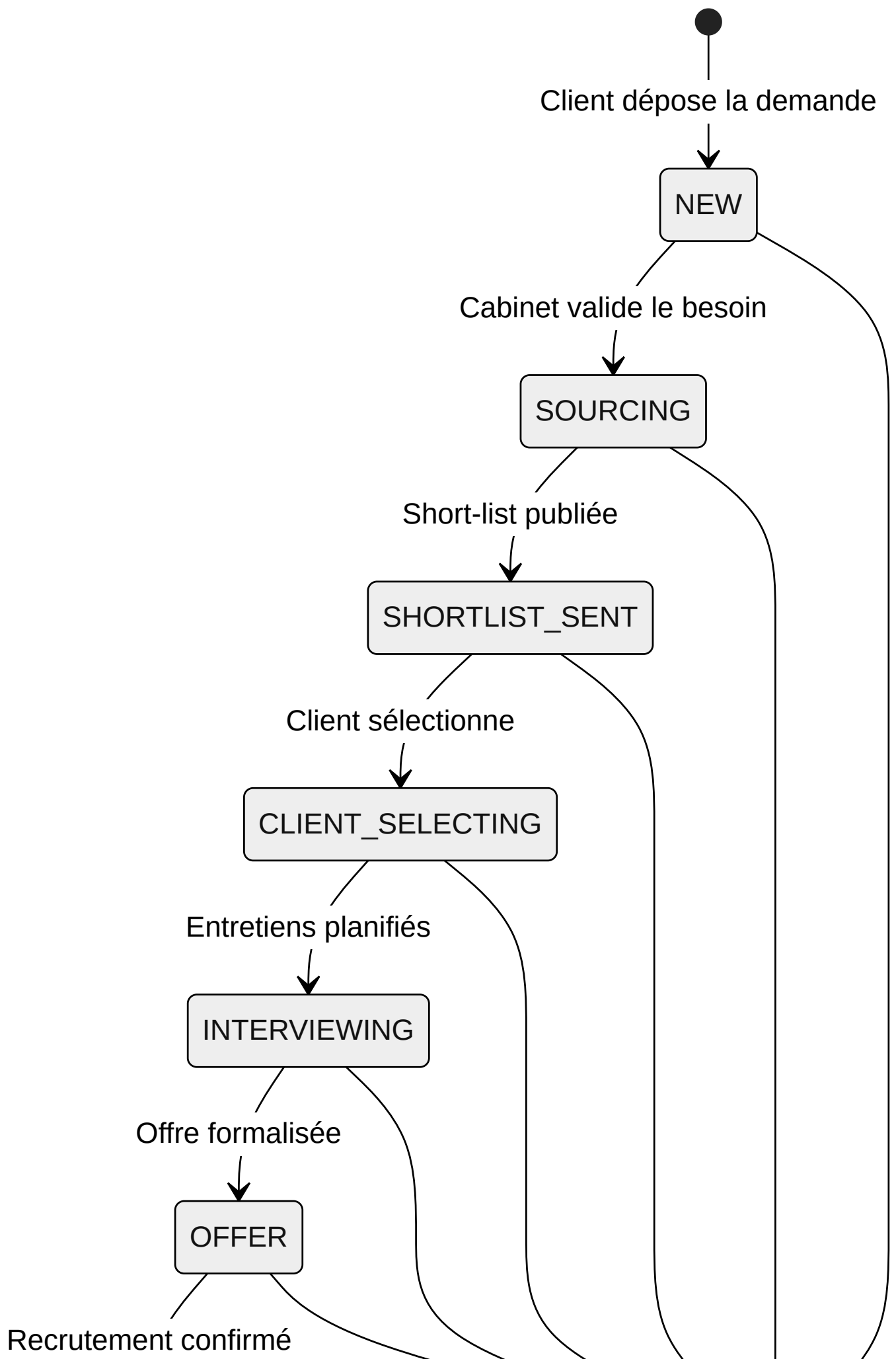
`User` porte le rôle (`CLIENT` / `CABINET` / `CANDIDATE`) et se relie à exactement un des trois profils selon ce rôle. `Mandat` est l'entité pivot du cœur de métier ; `JobPosting` celle du job board public — les deux peuvent être liées lorsqu'un mandat est aussi publié comme offre publique.

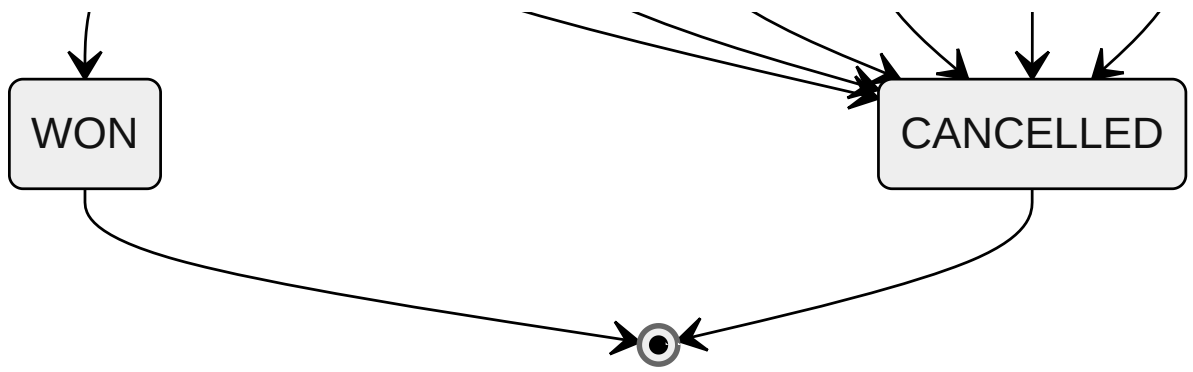
Domaines de modèles

DOMAINE	MODÈLES
Identité & comptes	User , Company , ClientProfile , CabinetProfile , CabinetInvite , Candidate
Mandats	Mandat , MandatStatusEvent , MandatMessage , MandateApplication
Entretiens	Interview , InterviewSlot
Job board	JobPosting , JobApplication , DirectMessage , JobSponsorship , JobAlert
Formations	TrainingCourse , TrainingSession , Enrollment
Transverse	Notification

04 Machine à états du mandat

Chaque transition passe par `mandatStateMachine.ts`, qui refuse tout saut d'étape et journalise le changement.

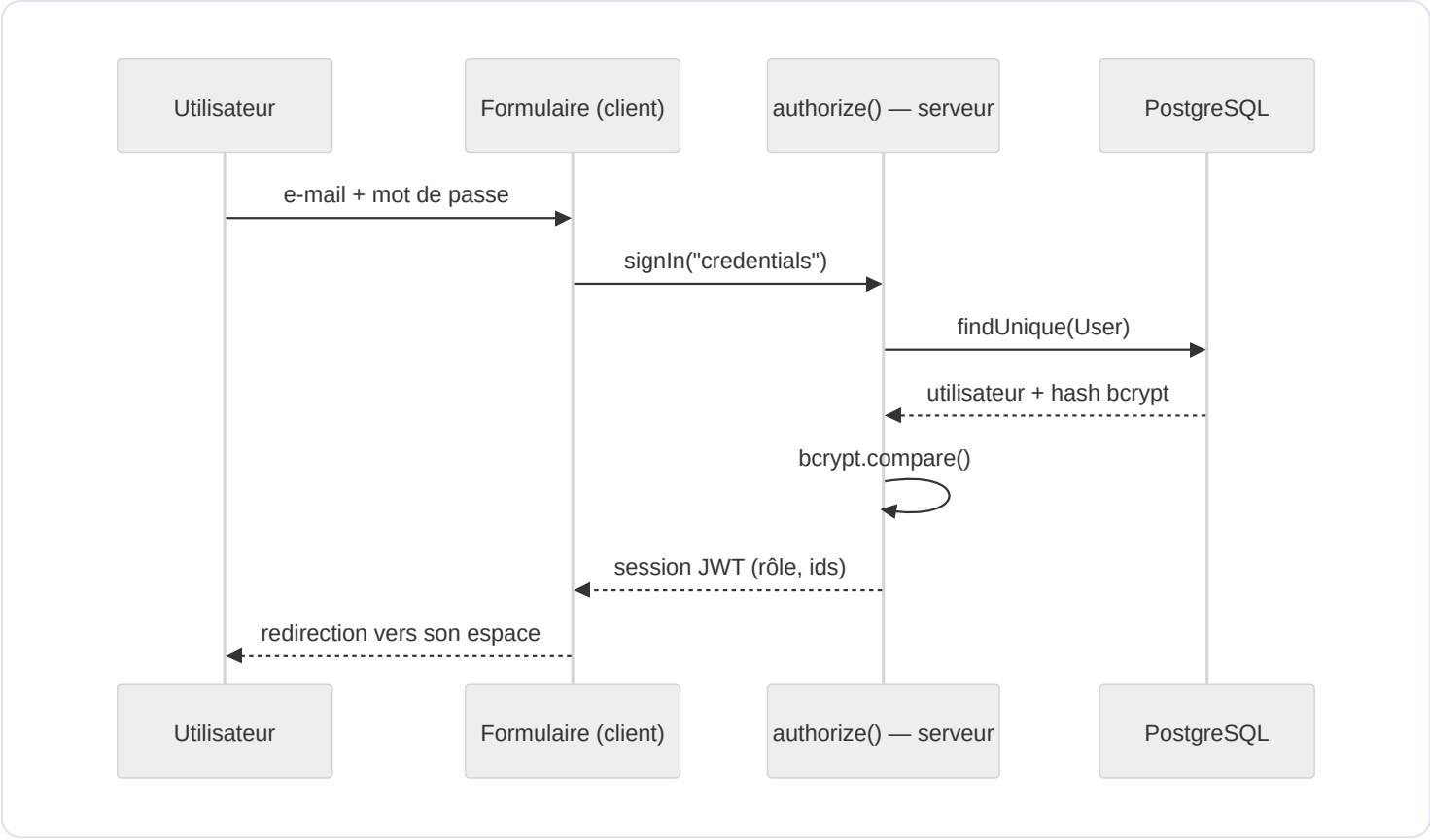




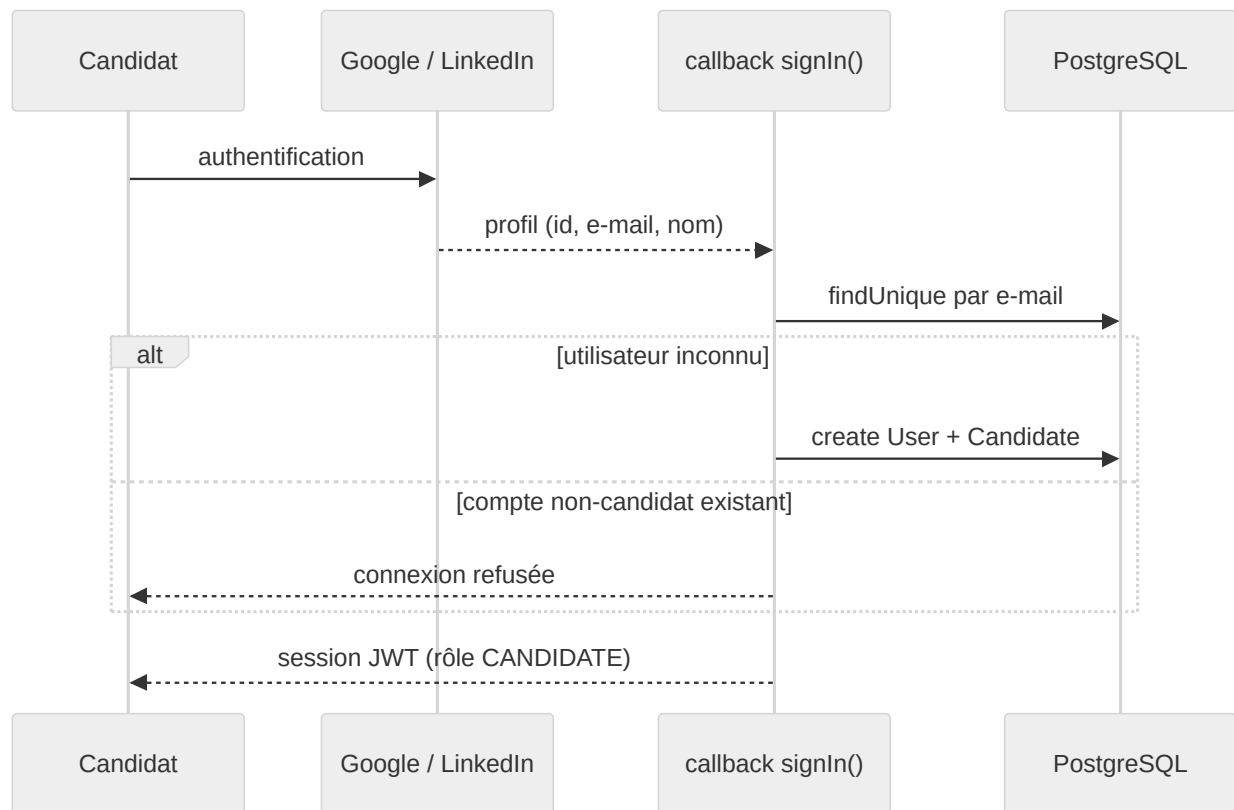
Sept statuts non terminaux, deux issues finales (**WON** / **CANCELLED**). L'annulation est accessible depuis n'importe quel statut non terminal ; aucune transition arrière n'est autorisée.

05 Flux d'authentification

Connexion par e-mail et mot de passe



Connexion sociale (Google / LinkedIn, candidats)



La connexion sociale est bloquée si l'e-mail correspond déjà à un compte Client ou Cabinet — elle ne peut jamais changer silencieusement le rôle d'un compte existant.

06 Sécurité en profondeur

Aucune couche ne fait confiance à la précédente — chaque niveau revérifie indépendamment.

NIVEAU	CONTRÔLE
Middleware (Edge)	Redirige vers <code>/login</code> tout accès non authentifié aux routes protégées
Layout de façade (RSC)	Revérifie le rôle exact ; redirige vers le bon espace si mauvais rôle
Server action	Revérifie rôle + propriété des données (ex : <code>mandat.companyId === user.companyId</code>) avant toute lecture ou écriture
Base de données	Contraintes d'unicité et clés étrangères Prisma (ex : une seule candidature par offre et par candidat)
Limitation de fréquence	Table <code>RateLimitAttempt</code> , fenêtre glissante par clé (connexion, inscription, candidature...) — indépendante du succès/échec pour ne jamais révéler l'état d'un compte
Upload de fichiers	Signature binaire (magic bytes) vérifiée contre une liste blanche, jamais l'extension déclarée par le client
Double authentification	Second facteur TOTP (ou code de secours à usage unique) exigé dans <code>authorize()</code> avant toute émission de session, pour les comptes cabinet qui l'ont activée

Comptes cabinet

Jamais d'inscription libre : uniquement par invitation (`CabinetInvite`) créée par un administrateur déjà en poste, à partir d'un compte d'amorçage créé par le script de seed.

07 Modules ajoutés (v2)

Cinq sous-systèmes ajoutés après la première version fonctionnelle, suivant les mêmes principes architecturaux que le cœur du produit (server actions, machine à états, revérification à chaque couche).

Machine à états du pipeline de prospection

`prospectStateMachine.ts` reproduit exactement le patron de `mandatStateMachine.ts` : une table de transitions autorisées (`PROSPECT` → `CONTACTED` → `QUALIFIED` → `MEETING` → `NEED_CONFIRMED` → `PROPOSAL` → `NEGOTIATION` → `WON`), un statut terminal `LOST` atteignable depuis n'importe quelle étape non terminale, et un journal d'audit (`ProspectStageEvent`) créé dans la même transaction que chaque changement d'étape.

Facturation

ÉTAPE	DÉTAIL
1. Confirmation de paiement	Le cabinet confirme un paiement manuel (sponsoring, CVthèque, formation)
2. Création du reçu	Dans la même transaction Prisma, <code>createInvoice()</code> attribue un numéro séquentiel (<code>INV-{année}-{0000}</code>) et enregistre le montant, la devise et la source
3. Génération à la demande	Le PDF n'est pas stocké : <code>generateInvoicePdf()</code> (pdfkit) le régénère à chaque téléchargement à partir des données en base
4. Contrôle d'accès	<code>api/invoices/[invoiceId]/route.ts</code> vérifie que l'appelant est le titulaire du reçu ou un compte cabinet avant de le servir

Double authentification (TOTP)

Enrôlement : génération d'un secret (`otplib`), affichage d'un QR code (`qrcode`) et confirmation par un premier code avant activation — le secret n'est jamais activé sans preuve que l'application d'authentification a bien été configurée. Connexion : le formulaire interroge `checkRequiresMfa()` pour savoir si un second champ doit apparaître, mais la vérification qui compte est toujours celle d' `authorize()` côté serveur, jamais une simple condition d'affichage côté client.

CVthèque

La recherche de candidats est ouverte à toute entreprise cliente ; seul l'accès aux coordonnées est conditionné à un `CvDatabaseAccess` confirmé et non expiré pour l'entreprise. Le résultat d'une recherche est calculé une seule fois côté serveur puis affiché sous deux formes différentes (identités masquées ou coordonnées visibles) selon ce même statut — pas deux requêtes séparées.

Droit à l'oubli

Le compte `User` n'est jamais supprimé par cascade — trop de tables (mandats, messages, avis, offres) le référencent comme auteur pour des besoins d'historique. La suppression anonymise les champs personnels en place et efface uniquement les données strictement

personnelles (CV, alertes, notifications, jetons), dans une transaction unique. Un compte cabinet ne peut pas supprimer le sien s'il est l'unique administrateur restant.